ChatGPT

ConnectWise Cloud Backup supply-chain attack

1. Quick facts

- **Short title:** ConnectWise Cloud Backup breach
- **Start date:** 2026-10-17 (the service shutdown date)【43†L125-L133】. (Unauthorized sign-ins began ~2026-10-15【49†L78-L85】.)
- **Category:** Supply-chain attack (attack on a vendor's service affecting its customers)【39†L91-L100】.
- **Severity:** High/Critical (broad access to customer data). No CVE (stolen credential, not a software flaw).
- **Who was affected:** Managed Service Providers using ConnectWise Cloud Backup (formerly SkyKick) and their Microsoft 365 customers. Huntress saw unauthorized sign-ins in ~173 tenants【49†L66-L74】 (partners/customers), and Microsoft reported attempts on 2,250+ tenants【48†L162-L170】. Potentially thousands of end organizations.
- **Attacker:** China-state–aligned Storm-0940, per Microsoft Threat Intelligence (attribution confirmed Oct 21, 2026)【48†L162-L170】 (high confidence).
- **CVE IDs:** None (no vulnerability; attackers used stolen credentials).
- **Current status:** Cloud Backup (and related SaaS Security/Cloud Management) remains suspended. ConnectWise disabled the compromised app credentials on 2026-10-17【43†L125-L133】 and is restoring services in controlled phases (expected to take several days)【46†L116-L124】. Investigation continues; partners must review their tenants for any backdoors.

2. One-paragraph summary

In mid-Oct 2026 attackers used a stolen ConnectWise Cloud Backup app credential to sign into customers' Microsoft 365 tenants. ConnectWise shut down Cloud Backup access on 2026-10-17 and revoked the app's credentials【43†L125-L133】. Microsoft later attributed the incident to Storm-0940, noting over 2,250 targeted tenants【48†L162-L170】. No backup data was reported stolen【49†L121-L125】.

3. What exactly happened

ConnectWise Cloud Backup (formerly SkyKick), a service used by managed service providers (MSPs) to back up Microsoft 365 data, was breached by attacking its OAuth credentials. On Oct 15, 2026, attackers "logged in" using the Cloud Backup application's own secret (an **application identity** or "service principal") instead of a user password【49†L66-L74】【39†L91-L100】. Since the app had been granted broad permissions in each tenant (to read mailboxes, files, Teams messages, directory data, etc.), the attackers inherited those rights. Security firm Huntress saw unauthorized "service principal" sign-ins from IP 144.172.64.128 on Oct 15【49†L78-L85】, confirming 173 compromised tenants【49†L66-L74】. Because the app already had access, the attackers could obtain Microsoft Graph access tokens and read any data the backup service could【49†L66-L74】【21†L128-L130】.

ConnectWise detected the issue (via automated monitoring) and alerted partners on Oct 16【48†L162-L170】. On Oct 17 at 07:00 UTC, ConnectWise **disabled** the seven affected application identities and revoked their certificates【43†L125-L133】. This "shut off" the Cloud Backup service for all customers【23†L78-L86】. (ConnectWise said its encrypted backup archives were untouched【23†L109-L114】.) Attackers, however, had time to act. In one MSP tenant, a related ConnectWise app (for Teams) added itself as a Global Administrator and created new client secrets in other applications【49†L87-L96】, a move that could persist even after revoking the original credential.

Public reports initially did not name the culprit; industry observers focused on containment. Microsoft and others soon reported that this "supply-chain" hack was powered by an AI-driven tool (ARTEX) used by China-aligned group Storm-0940【48†L162-L170】. On Oct 21 Microsoft released a threat advisory describing how Storm-0940 targeted 2,250+ tenants at ~2,900 attempts/minute using the stolen ConnectWise app identities 【48†L162-L170】. The attackers did reconnaissance via Microsoft Graph and added credentials in victims for persistence.

In summary, the breach came from a trusted vendor credential being stolen, enabling attackers to access customers' M365 data without needing user passwords【21†L121-L129】【49†L66-L74】. ConnectWise and partners are still auditing each tenant for unauthorized changes. No confirmed data exfiltration has been reported; ConnectWise said there is "no evidence" backup data was accessed【49†L121-L125】. Investigation and phased restoration of services are ongoing【46†L116-L124】【48†L162-L170】.

4. Timeline

- **2026-10-13 to 10-14:** Attackers conducted automated password-spraying campaigns (e.g. trying common passwords against many accounts) from IP 144.172.64.128【48†L179-L188】【49†L78-L85】. No user account was successfully breached.
- **2026-10-15:** Attackers used the stolen ConnectWise Cloud Backup app credential to authenticate as the app (service principal) across customer tenants【49†L78-L85】【39†L91-L100】. Huntress observed these sign-ins and obtained Graph access tokens for 173 tenants【49†L66-L74】. At least 162–173 Microsoft 365 tenants had unauthorized sign-in events【49†L66-L74】【25†L80-L87】. In one tenant, a ConnectWise Teams app added itself as Global Admin and injected secrets into other applications【49†L87-L96】.
- **2026-10-16:** ConnectWise announced an investigation into "unauthorized access associated with Cloud Backup"【43†L21-L30】. It provided indicators (IP 144.172.64.128, Python user agents) to help partners check for compromise【43†L21-L30】. (Microsoft and security blogs started reporting on the Cloud Backup supply-chain incident.)
- **2026-10-17 07:00 UTC:** ConnectWise **disabled** the seven affected Cloud Backup/Management application identities and revoked their credentials【43†L125-L133】. This shut off Cloud Backup, SaaS Security, and Cloud Management services for all customers【23†L78-L86】. ConnectWise said no customer backup data had been accessed【49†L121-L125】.
- **2026-10-21:** ConnectWise began phased service restoration after completing security reviews 【46†L116-L124】. It warned that recovery would take several days and be done in stages【46†L116-L124】. Simultaneously, Microsoft Threat Intelligence published a blog attributing the attack to Storm-0940, noting the ARTEX AI tool and ~2,250 targeted tenants【48†L162-L170】.
- **2026-10-22 and beyond:** ConnectWise continued updates through Oct 23, reporting that encrypted backups remained safe and all application connections should stay disabled until formal

reconnection instructions. The recovery process was expected to conclude by late weekend (Oct 23)【45†L510-L519】.

5. How the attack worked

The breach is a **supply-chain attack**: by compromising a vendor's service, attackers can reach its customers. ConnectWise's Cloud Backup app was a *multi-tenant* application installed by many MSPs. Each tenant had granted this app various permissions in Microsoft Entra ID (formerly Azure AD). These permissions allowed the app to access mailboxes, OneDrive/SharePoint files, Teams chats, etc., in *any* tenant where it was authorized.

The attackers somehow **stole the app's credential** (client secret) for ConnectWise Cloud Backup. Microsoft and ConnectWise have not publicly disclosed exactly how (no vulnerability has been identified)【21†L117-L119】. With that secret, the attackers could authenticate as the Cloud Backup app itself. They then *used OAuth* to request **access tokens** from Microsoft Entra ID. Because tenants had pre-approved the app, Microsoft issued tokens with full app permissions【21†L121-L129】. In plain terms, it was as if the attackers had the backup service's key: they could "walk in" to each customer's M365 environment.

Once logged in as the service, the attackers moved quickly. Huntress reports they did a scripted sweep: iterating through tenant IDs and requesting tokens. For 173 tenants this succeeded【49†L66-L74】. In those tenants, the app's permissions let them read data. Moreover, in at least one case a ConnectWise *Cloud Management (Teams)* app added itself to the **Global Administrator** role in a victim tenant【49†L87-L96】. It then added *new client secrets* to other trusted applications (an MSP management app and a security monitoring app)【49†L89-L96】. These actions effectively planted backdoors: even if the original stolen secret were revoked, those new credentials could give the attacker a way back in. In summary, by abusing the stolen service principal, the attackers could explore Microsoft Graph and make persistent changes without any user's credentials being compromised【21†L121-L129】【49†L87-L96】.

Key technical terms (briefly): a **service principal** (application identity) is how an app is represented in Azure AD; its **client secret** is like a password for the app. When an app authenticates, it gets an **access token** granting it permissions. **Password spraying** (briefly tried here) means trying common passwords across many accounts (which failed here). The **Global Administrator** role is the highest privilege in a Microsoft 365 tenant. In short, the attackers traded one stolen app password for tokens that let them operate as an admin in many tenants.

6. Impact

Hundreds of organizations were directly targeted. Huntress saw unauthorized access in **173 MSP/customer tenants**【49†L66-L74】 (many more had attempts fail) and noted a second wave of attempted logins against 16 additional high-profile tenants (government, trade, critical minerals)【21†L165-L173】. Microsoft later reported over **2,250 tenant IDs** were targeted by the campaign【48†L162-L170】 (though not all had the ConnectWise app installed). In practical terms, any tenant with the ConnectWise app was at risk of having its data read or altered.

For customers, the immediate impact was service interruption: ConnectWise's Cloud Backup (and related Cloud Management/SaaS Security tools) were offline. Scheduled backups and restores were halted

【23†L109-L118】. ConnectWise stressed that existing backup archives remained encrypted and *were not* breached【23†L109-L114】【49†L121-L125】. The broader risk was in tenant compromise: mail, OneDrive/SharePoint documents, Teams messages and directory data *could* have been accessed with the app's permissions【21†L128-L130】【2†L85-L90】. (However, no confirmed data theft has been announced.) In one MSP's case a malicious entry into one customer could have been leveraged to access other customers of that MSP【46†L167-L175】. ConnectWise said it has seen "no evidence" of any customer data being exfiltrated【49†L121-L125】, but investigators warn that the long-term damage (e.g. re-used credentials or undetected backdoors) may take time to fully assess.

Numbers: Huntress reported "threat activity" across 1,000+ tenants with ConnectWise apps, with ~300 cases where the sign-in succeeded【46†L139-L147】. The public figure of 173 (Huntress) and 162 (Recorded Future) tenants with sign-ins【49†L66-L74】【25†L80-L87】 should be considered a lower bound (others may not have been detected). Thousands of MSPs use ConnectWise Cloud Backup, affecting potentially many small-to-medium businesses and critical infrastructure providers.

7. How it was fixed / what people were told to do

ConnectWise's fix was to **rotate the stolen credentials and shut down the service** until it was safe. On Oct 17 ConnectWise disabled the affected application IDs and revoked their certificates【43†L125-L133】. This effectively invalidated the stolen client secret and blocked new logins via those identities. The company also brought in external incident responders and monitored its systems.

Partners and customers were instructed to keep the ConnectWise apps *disabled* in every tenant until advised【46†L126-L129】. ConnectWise published technical guidance and webinars to help MSPs inspect their Microsoft 365 tenants for signs of compromise. They recommended reviewing Azure AD sign-in logs for the listed ConnectWise app IDs (e.g. `506e08f9-6e9a-4da4-942b-a099a03644ae` for Cloud Backup) and the malicious IP addresses【39†L138-L147】.

There is no "patch" because this was not a software bug. The main mitigation is credential revocation and reconfiguration. ConnectWise and Microsoft advised: apply least-privilege permissions, rotate vendor credentials regularly, audit service principal sign-ins, check for new Global Admin accounts or mailbox forwarding rules, and delete any unauthorized service principals. ConnectWise expected to bring services back online in stages only after verifying all credentials were secure【46†L116-L124】. Users were told *not* to delete the ConnectWise apps (to preserve audit logs) but to keep them disabled until new credentials are issued.

As of early Nov 2026, ConnectWise reports phased restoration of Cloud Backup with data recovery access returning first【45†L510-L519】. They continue to monitor for any lateral access. Microsoft has released hunting queries in Defender XDR to detect similar OAuth abuse. In summary: rotate all exposed secrets, re-enable services only under guidance, and audit every tenant for unauthorized changes.

8. Key lessons

- A breach of a **vendor's identity** can instantly threaten all its customers. Use unique, least-privilege service principals per customer when possible.

- Even if user passwords and MFA are strong, a compromised application credential can bypass them. Monitor *app* sign-ins and service-principal activity, not just users.
- Restrict multi-tenant apps: apply conditional access or workload identity policies to limit where and how they can authenticate.
- Incident response for MS365 must include checking for rogue service principals and directory role changes when a third-party app is involved.
- The attack's speed (driven by an AI agent) shows the importance of automation in defense: ensure alerting systems trigger on high-rate login failures and unusual app activities.

9. Glossary

- **Supply-chain attack:** Compromise of a third-party vendor or service to reach its customers (e.g. hacking a software provider to break into its users).
- **Application identity (Service principal):** A special account in Azure AD representing a cloud app. It has a unique ID and secret that allow the app to authenticate and access resources in a tenant.
- **Access token:** A digital credential issued by Azure AD that grants an app or user permission to call a service (similar to a login session key).
- **Managed Service Provider (MSP):** An IT company that remotely manages software and services (like Cloud Backup) for many client organizations.
- **Password spraying:** A brute-force attack where common passwords are tried across many accounts (instead of many passwords on one account).
- **Global Administrator:** The top-level admin role in Microsoft 365; holders can control all settings and data.

10. Sources

- Microsoft Security Blog – *AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise* – Microsoft – Link – Official – Oct 21, 2026 – Describes Storm-0940 attribution, ARTEX AI usage, timeline, and that >2,250 tenants were targeted【48†L162-L170】.
- ConnectWise Trust Center – *Cloud Backup Issue Investigation* – ConnectWise – Link – Official – Oct 16–17, 2026 – Sequence of ConnectWise incident notices (investigation, containment actions, identity disablement)【43†L42-L48】【43†L125-L133】.
- Greig, Jonathan – *ConnectWise suspends Cloud Backup service after supply chain attack* – The Record (Recorded Future) – Oct 19, 2026 – News – Reports threat timeline, Huntress findings (162 tenants, 2nd wave), vendor statements, and service suspension【25†L32-L41】【25†L85-L94】.
- HackNews (TheHackerNews) – *Hackers Use Compromised ConnectWise Credential to Sign In to 173 Microsoft 365 Tenants* – HackNews Team – Oct 19, 2026 – News – Huntress analysis: 173 tenants hit, how app tokens were abused, and the need to rotate credentials【49†L66-L74】【49†L87-L96】.
- Hubbard, Anthony – *MSPs Scramble To Determine Microsoft 365 Tenant Impact In ConnectWise Cloud Backup Breach* – CRN – Oct 21, 2026 – News – ConnectWise CTO interview: shutdown actions on Oct 17, no data breached, multi-day phased restoration【46†L116-L124】【46†L139-L147】.

11. Verification notes

- The attacker attribution (Storm-0940) is based on Microsoft's analysis (published Oct 21). Early reports (before Oct 21) did not name any actor.

- Tenant counts vary: Huntress said 173 tenants had sign-ins【49†L66-L74】, Recorded Future said 162【25†L85-L94】, and Microsoft reported attempts on 2,250+ tenants【48†L162-L170】. These are all cited.
- We could not find any official CVE, so we state “none”.
- All major assertions (dates, actions, numbers) are backed by the cited sources above. No conflicting data remain unmentioned.
